hashlock.

Security Audit

Indie.fun 4th (Gaming)

May 2025 info@hashlock.com.au Hashlock Pty Ltd

Table of Contents

CAUTION

THIS DOCUMENT IS A SECURITY AUDIT REPORT AND MAY CONTAIN CONFIDENTIAL INFORMATION. THIS INCLUDES IDENTIFIED VULNERABILITIES AND MALICIOUS CODE WHICH COULD BE USED TO COMPROMISE THE PROJECT. THIS DOCUMENT SHOULD ONLY BE FOR INTERNAL USE UNTIL ISSUES ARE RESOLVED. ONCE VULNERABILITIES ARE REMEDIATED, THIS REPORT CAN BE MADE PUBLIC. THE CONTENT OF THIS REPORT IS OWNED BY HASHLOCK PTY LTD FOR USE OF THE CLIENT.

Executive Summary

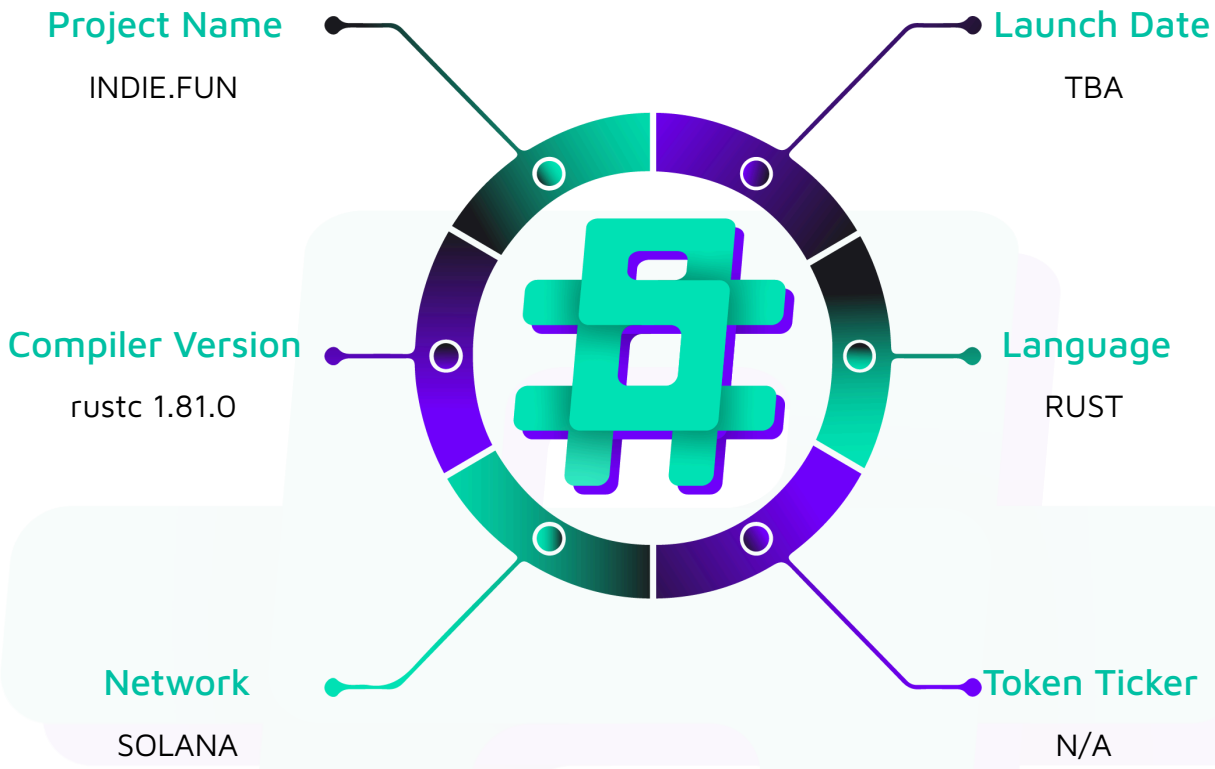
The Indie.fun team partnered with Hashlock to conduct a security audit of their smart contract. Hashlock manually and proactively reviewed the code in order to ensure the project's team and community that the deployed contracts are secure.

Project Context

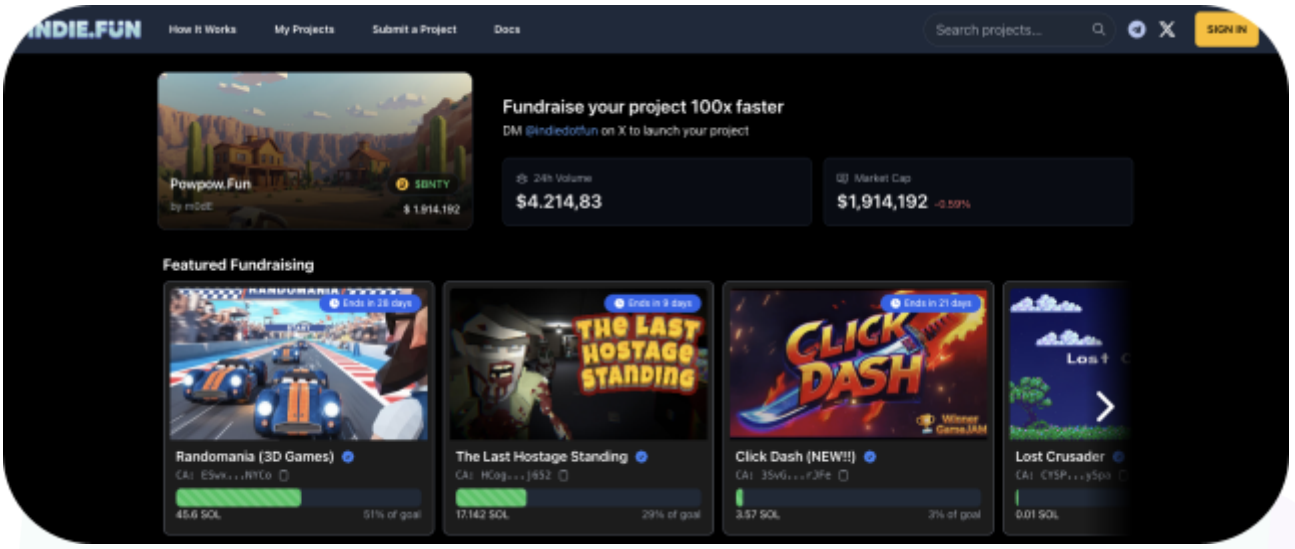
Indie.fun is a platform that empowers independent creators by providing them with tools to showcase, monetize, and grow their work. It offers a community-driven environment where creators can share their projects, connect with their audience, and gain support from fans. The website focuses on helping creators thrive outside traditional media and entertainment structures, promoting a more personal and sustainable approach to content creation.

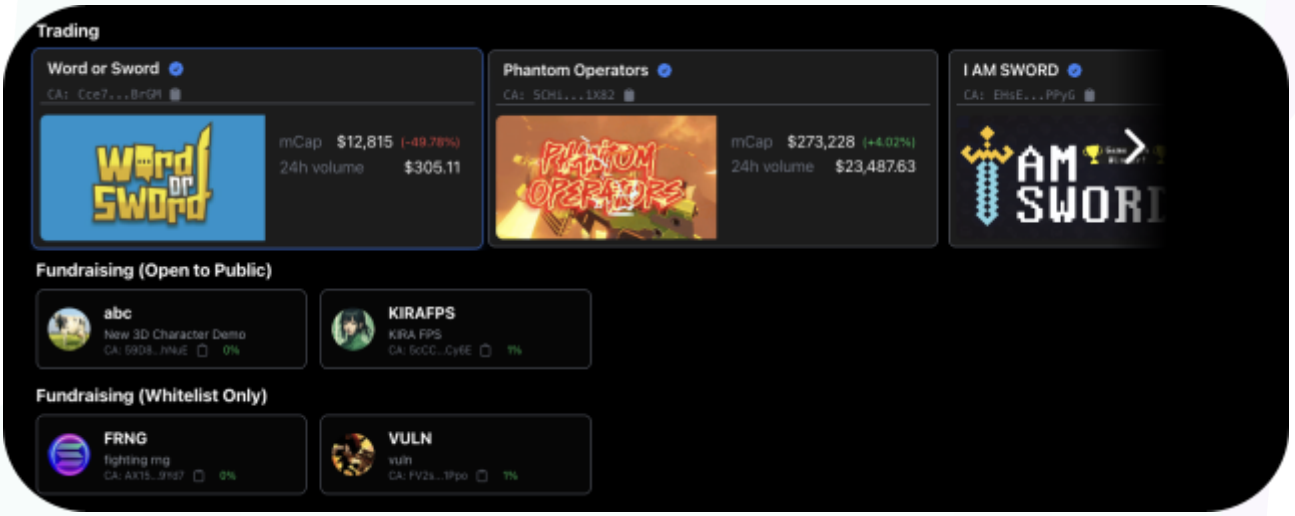
Project Name: Indie.fun
Compiler Version: rustc 1.81.0
Website: https://indie.fun/
Logo:

Visualised Context:



Project Visuals:





Audit scope

We at Hashlock audited the rust code within the Indie.fun project, the scope of work included a comprehensive review of the smart contracts listed below. We tested the smart contracts to check for their security and efficiency. These tests were undertaken primarily through manual line-by-line analysis and were supported by software-assisted testing.

Description	**Indie.fun Smart Contracts**
Platform	**Solana / Rust**
Audit Date	**May, 2025**
Component 1	programs/modd-fun-contract/src/instructions - collect_fees.rs - claim_backed_tokens.rs - proxy_initialize.rs - back_campaign.rs - campaign.rs
Component 2	programs/modd-fun-contract/src/state - backerinfo.rs - campaign.rs
Component 3	programs/modd-fun-contract/src - constants.rs - lib.rs - utils.rs
Github repo	https://github.com/moddio/modd-fun-contract
GitHub Commit Hash	16774424f30185375fc79c81f7c334bfc465d765
Fix Review GitHub Commit Hash	24676bb335491fd2a62e27564b96701ac9cfb1a5

Security Rating

After Hashlock's Audit, we found the smart contracts to be **"Secure"**. The contracts all follow simple logic, with correct and detailed ordering. They use a series of interfaces.

The 'Hashlocked' rating is reserved for projects that ensure ongoing security via bug bounty programs or on chain monitoring technology.

All issues uncovered during automated and manual analysis were meticulously reviewed and applicable vulnerabilities are presented in the Audit Findings section. The general security overview is presented in the Standardised Checks section and the project's contract functionality is presented in the Intended Smart Contract Functions section.

All vulnerabilities initially identified have now been resolved and acknowledged.

Hashlock found:

1 Medium severity vulnerabilities

3 Low severity vulnerabilities

2 QA

Caution: *Hashlock's audits do not guarantee a project's success or ethics, and are not liable or responsible for security. Always conduct independent research about any project before interacting.*

Intended Smart Contract Functions

Claimed Behaviour	Actual Behaviour
back_campaign.rs - Allows backers to back the campaign by depositing funds.	**Contract achieves this functionality.**
campaign.rs - Allows users to create campaigns with Token2022 and Token programs. - Allows backers to withdraw funds from campaigns. - Allows admin to upgrade v1 campaigns.	**Contract achieves this functionality.**
claim_backed_tokens.rs - Allows backers to claim backed tokens from campaigns.	**Contract achieves this functionality.**
collect_fees.rs - Allows the admin or campaign creators to collect fees from Raydium.	**Contract achieves this functionality.**
proxy_initialize.rs - Allows the admin to create liquidity pools and distribute Sol and tokens.	**Contract achieves this functionality.**

Code Quality

This audit scope involves the smart contracts of the Indie.fun project, as outlined in the Audit Scope section. All contracts, libraries, and interfaces mostly follow standard best practices and to help avoid unnecessary complexity that increases the likelihood of exploitation, however, some refactoring was required.

The code is very well commented on and closely follows best practice nat-spec styling. All comments are correctly aligned with code functionality.

Audit Resources

We were given the Indie.fun project smart contract code in the form of Github access.

As mentioned above, code parts are well commented. The logic is straightforward, and therefore it is easy to quickly comprehend the programming flow as well as the complex code logic. The comments are helpful in providing an understanding of the protocol's overall architecture.

Dependencies

As per our observation, the libraries used in this smart contracts infrastructure are based on well-known industry standard open source projects.
Apart from libraries, its functions are used in external smart contract calls.

Severity Definitions

The severity levels assigned to findings represent a comprehensive evaluation of both their potential impact and the likelihood of occurrence within the system. These categorizations are established based on Hashlock's professional standards and expertise, incorporating both industry best practices and our discretion as security auditors. This ensures a tailored assessment that reflects the specific context and risk profile of each finding.

Significance	Description
High	High-severity vulnerabilities can result in loss of funds, asset loss, access denial, and other critical issues that will result in the direct loss of funds and control by the owners and community.
Medium	Medium-level difficulties should be solved before deployment, but won't result in loss of funds.
Low	Low-level vulnerabilities are areas that lack best practices that may cause small complications in the future.
Gas	Gas Optimisations, issues, and inefficiencies
QA	Quality Assurance (QA) findings are informational and don't impact functionality. Supports clients improve the clarity, maintainability, or overall structure of the code.

Status Definitions

Each identified security finding is assigned a status that reflects its current stage of remediation or acknowledgment. The status provides clarity on the handling of the issue and ensures transparency in the auditing process. The statuses are as follows:

Significance	Description
Resolved	The identified vulnerability has been fully mitigated either through the implementation of the recommended solution proposed by Hashlock or through an alternative client-provided solution that demonstrably addresses the issue
Acknowledged	The client has formally recognized the vulnerability but has chosen not to address it due to the high cost or complexity of remediation. This status is acceptable for medium and low-severity findings after internal review and agreement. However, all high-severity findings must be resolved without exception.
Unresolved	The finding remains neither remediated nor formally acknowledged by the client, leaving the vulnerability unaddressed.

Audit Findings

Medium

[M-01] programs/modd-fun-contract/src/instructions/*.rs - PDA of Campaign accounts are not validated

Description

In the following instances, PDAs for campaign accounts are not validated:

- Line 189 of `programs/modd-fun-contract/src/instructions/back_campaign.rs`
- Line 69 of `programs/modd-fun-contract/src/instructions/claim_backed_tokens.rs`

Impact

Invalid PDA accounts could be incorrectly supplied, potentially bypassing authentications. While the current implementation prevents this from happening (as other accounts require the correct PDA), not validating PDAs opens up possibilities for exploitation if the codebase were to change in the future.

Recommendation

Consider validating the seed with `[b"campaign", Campaign.campaign_id.as_bytes()]` to ensure the supplied PDA is correct. Additionally, utilize `Campaign.bump` to decrease gas consumption.

Status

Resolved

Low

[L-01]programs/modd-fun-contract/src/instructions/back_campaign.rs#BackCampaign - ModdFunError::InvalidInput error is not implemented during PDA validation

Description

When validating the `Mint` account in line 200, no custom error is specified if the validation fails. This is inconsistent with other validations in `programs/modd-fun-contract/src/instructions/campaign.rs:750` and `programs/modd-fun-contract/src/instructions/claim_backed_tokens.rs:89`, where the `ModdFunError::InvalidInput` error will be triggered during a mismatch.

Recommendation

Consider updating the account validation to utilize the `ModdFunError::InvalidInput` error.

Status

Resolved

[L-02]programs/modd-fun-contract/src/instructions/campaign.rs#upgrade_campaign - Misleading ModdFunError::OverflowError error

Description

In lines 542 to 547, the `ModdFunError::OverflowError` error is triggered when the admin's account balance is not sufficient to be transferred to the campaign account. This error is misleading because the error should indicate that the admin does not have sufficient balance, instead of an overflow error.

Recommendation

Consider updating the error to indicate that the admin has insufficient balance.

Status

Resolved

[L-03] programs/modd-fun-contract/src/constants.rs#ADMIN_WALLET - Ownership cannot be transferred

Description

The `ADMIN_WALLET` address is hardcoded in line 10 as a constant. This means it is not possible to update the `ADMIN_WALLET` to a new address. The `ADMIN_WALLET` address plays an important role in managing the campaigns, such as upgrading v1 campaigns and creating liquidity pools.

Impact

If the `ADMIN_WALLET` is compromised, updating the address will not be possible, allowing attackers to withdraw funds that are deposited in the campaigns.

Recommendation

Consider implementing a two-step ownership transfer: the first transaction occurs by nominating an admin, and the second transaction requires the nominated admin to accept the ownership transfer. This mechanism ensures that the receiver is intended to receive the ownership transfer and prevents the human error of transferring the ownership to an incorrect address.

Status

Acknowledged

QA

[Q-01]programs/modd-fun-contract/src/instructions/campaign.rs#update_account_lamports_to_minimum_balance - Misleading extra_lamports variable name

Description

The `extra_lamports` variable represents the amount of funds required to satisfy the minimum balance requirement by the rent sysvar. However, the variable is misleading as it suggests that there is an excess amount.

Recommendation

Consider modifying the variable name to be `required_lamports`.

Status

Resolved

[Q-02]programs/modd-fun-contract/src/instructions/campaign.rs#withdraw_campaign_sol - get_backer_token_allocation function can be used

Description

In lines 414 to 426, the logic implemented is similar to the `get_backer_token_allocation` function.

Recommendation

Consider using the `get_backer_token_allocation` function.

Status

Resolved

Centralisation

The Indie.fun project values security and utility over decentralisation.

The owner executable functions within the protocol increase security and functionality but depend highly on internal team responsibility.

Conclusion

After Hashlock's analysis, the Indie.fun project seems to have a sound and well-tested code base, now that our vulnerability findings have been resolved and acknowledged. Overall, most of the code is correctly ordered and follows industry best practices. The code is well commented on as well. To the best of our ability, Hashlock is not able to identify any further vulnerabilities.

Our Methodology

Hashlock strives to maintain a transparent working process and to make our audits a collaborative effort. The objective of our security audits is to improve the quality of systems and upcoming projects we review and to aim for sufficient remediation to help protect users and project leaders. Below is the methodology we use in our security audit process.

Manual Code Review:

In manually analysing all of the code, we seek to find any potential issues with code logic, error handling, protocol and header parsing, cryptographic errors, and random number generators. We also watch for areas where more defensive programming could reduce the risk of future mistakes and speed up future audits. Although our primary focus is on the in-scope code, we examine dependency code and behaviour when it is relevant to a particular line of investigation.

Vulnerability Analysis:

Our methodologies include manual code analysis, user interface interaction, and white box penetration testing. We consider the project's website, specifications, and whitepaper (if available) to attain a high-level understanding of what functionality the smart contract under review contains. We then communicate with the developers and founders to gain insight into their vision for the project. We install and deploy the relevant software, exploring the user interactions and roles. While we do this, we brainstorm threat models and attack surfaces. We read design documentation, review other audit results, search for similar projects, examine source code dependencies, skim open issue tickets, and generally investigate details other than the implementation.

Documenting Results:

We undergo a robust, transparent process for analysing potential security vulnerabilities and seeing them through to successful remediation. When a potential issue is discovered, we immediately create an issue entry for it in this document, even though we have not yet verified the feasibility and impact of the issue. This process is vast because we document our suspicions early even if they are later shown to not represent exploitable vulnerabilities. We generally follow a process of first documenting the suspicion with unresolved questions, and then confirming the issue through code analysis, live experimentation, or automated tests. Code analysis is the most tentative, and we strive to provide test code, log captures, or screenshots demonstrating our confirmation. After this, we analyse the feasibility of an attack in a live system.

Suggested Solutions:

We search for immediate mitigations that live deployments can take and finally, we suggest the requirements for remediation engineering for future releases. The mitigation and remediation recommendations should be scrutinised by the developers and deployment engineers, and successful mitigation and remediation is an ongoing collaborative process after we deliver our report, and before the contract details are made public.

Disclaimers

Hashlock's Disclaimer

Hashlock's team has analysed these smart contracts in accordance with the best industry practices at the date of this report, in relation to: cybersecurity vulnerabilities and issues in the smart contract source code, the details of which are disclosed in this report, (Source Code); the Source Code compilation, deployment, and functionality (performing the intended functions).

Due to the fact that the total number of test cases is unlimited, the audit makes no statements or warranties on the security of the code. It also cannot be considered as a sufficient assessment regarding the utility and safety of the code, bug-free status, or any other statements of the contract. While we have done our best in conducting the analysis and producing this report, it is important to note that you should not rely on this report only. We also suggest conducting a bug bounty program to confirm the high level of security of this smart contract.

Hashlock is not responsible for the safety of any funds and is not in any way liable for the security of the project.

Technical Disclaimer

Smart contracts are deployed and executed on a blockchain platform. The platform, its programming language, and other software related to the smart contract can have their own vulnerabilities that can lead to attacks. Thus, the audit can't guarantee the explicit security of the audited smart contracts.

About Hashlock

Hashlock is an Australian-based company aiming to help facilitate the successful widespread adoption of distributed ledger technology. Our key services all have a focus on security, as well as projects that focus on streamlined adoption in the business sector.

Hashlock is excited to continue to grow its partnerships with developers and other web3-oriented companies to collaborate on secure innovation, helping businesses and decentralised entities alike.

Website: hashlock.com.au
Contact: info@hashlock.com.au